

1.1. Principios de seguridad y alta disponibilidad

Álvaro González Sotillo

13 de septiembre de 2026

Índice

1. Introducción	2
2. Definición de información	2
3. Definición de seguridad	2
4. Problemática de las redes de comunicaciones	3
5. ¿Qué debemos proteger?	3
6. Tipos de amenazas	7
7. Tipos de ataques	9
8. Análisis y gestión de riesgo	10
9. Proceso de análisis de riesgos informáticos	10
10.Herramientas de análisis y gestión de riesgos	10
11.Auditoría	11
12.Plan de contingencias	12
13.Referencias	12

1. Introducción



2. Definición de información

- En el entorno empresarial, la **información** se define como el activo que posee valor para una organización.
- Requiere una protección adecuada para:
 - Asegurar la **continuidad del negocio**
 - Minimizar los daños a la organización
 - Maximizar el retorno de las inversiones y las oportunidades de negocio

3. Definición de seguridad

- La **seguridad informática** es el conjunto de herramientas, técnicas, dispositivos y procedimientos orientados a conseguir, mejorar o garantizar determinados niveles de:
 - **Confidencialidad**
 - **Disponibilidad**
 - **Integridad**
 - **Autenticidad**
 - **No repudio**
- de la información con la que trabaja un sistema informático.
- Definiciones en la norma **ISO 27002**
 - Traducción al español: **UNE-ISO/IEC 17799**
- Cita de **Eugene H. Spafford**:

.^{EI} único sistema que es totalmente seguro es aquel que se encuentra apagado y desconectado, guardado en una caja fuerte de titanio que está enterrada en cemento, rodeada de gas nervioso y de un grupo de guardias fuertemente armados. **Aún así, no apostaría mi vida en ello.**"



4. Problemática de las redes de comunicaciones

- Compartimos recursos
- Sistema complejo
- Perímetro desconocido
- Múltiples puntos de ataque
- Todo ello genera **vulnerabilidades** en el sistema
 - Una **vulnerabilidad** es una debilidad de un activo o grupo de activos que puede ser explotada por una o más amenazas.
- Últimas vulnerabilidades

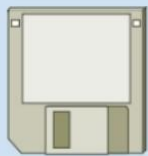
4.1. Análisis de vulnerabilidades

- Uso de **herramientas especializadas** para examinar sistemas:
 - Fallos de seguridad, configuraciones incorrectas o debilidades del software
 - Pruebas exhaustivas para identificar vulnerabilidades conocidas y desconocidas
- El **análisis manual** es fundamental
 - Inspecciones detalladas y personalizadas
 - Permite una comprensión más profunda de los sistemas y sus riesgos

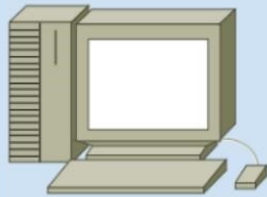
5. ¿Qué debemos proteger?

- Los sistemas informáticos (SSOO, servicios o aplicaciones) se dice que son **seguros** si cumplen las siguientes características u objetivos:

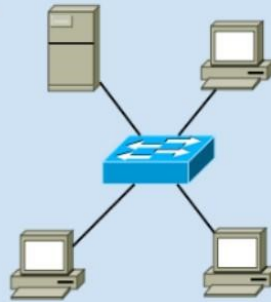
Triangulo CIA



INFORMACIÓN



**EQUIPAMIENTO
FÍSICO**



**REDES Y
COMUNICACIONES**



USUARIOS

INFORMACIÓN

Es lo que aporta valor al sistema informático, por lo que velaremos porque ni se deteriore, ni sea robada o copiada

EQUIPAMIENTO FÍSICO

Protegeremos al *hardware* tanto de ataques intencionados, como de accidentales

REDES Y COMUNICACIONES

Por las redes circula una gran cantidad de información, no sólo aquella susceptible de ser robada, sino información de control

USUARIOS

A veces son el punto más débil del sistema, por lo que necesitamos implantar procedimientos de control de acceso y de protección

5.1. Confidencialidad (o privacidad)

- Garantía de que la información sea accesible **solo** por aquellos usuarios o sistemas autorizados
- Ejemplo: cifrar un archivo con contraseña que solo conocen unos pocos usuarios

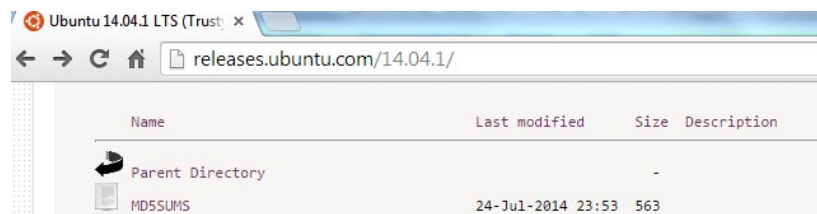
5.2. Integridad (o confiabilidad)

- La información es **la misma desde que fue generada**: que no se haya manipulado o corrompido
 - No puede ser modificada por personas no autorizadas
- Ejemplos:
 - Generar un código **hash** para un archivo
 - **Firmas digitales**
 - **Control de versiones**
 - Sistema de **detección de intrusos** (alertan sobre cambios no autorizados)
- Comprobación de integridad *anti-rootkit*:
 - Windows: **md5sum**, **SFC** (System File Checker)
 - GNU/Linux: **cksum**, **Rootkit Hunter**
- Un **pequeño cambio** en el contenido del archivo se transforma en un **gran cambio** en el valor del **sum**.

```
jcarlos@ldapserver: ~  
jcarlos@ldapserver:~$ echo "Prueba de integridad en Linux" > fichero  
jcarlos@ldapserver:~$ cksum fichero  
146841094 30 fichero  
jcarlos@ldapserver:~$ echo "Prueba de integridad en pinux" > fichero  
jcarlos@ldapserver:~$ cksum fichero  
1815305712 30 fichero  
jcarlos@ldapserver:~$
```

- Ejemplo práctico: **md5sum** en Windows

```
C:\Users\JuanCarlos\Downloads>md5sums g:\2-ISOS\ubuntu-14.04.1-desktop-i386.iso  
MD5sums 1.2 freeware for Win9x/ME/NT/2000/XP+  
Copyright (C) 2001-2005 Jem Berkes - http://www.pc-tools.net/  
Type md5sums -h for help  
  
[Path] / filename                                MD5 sum  
-----  
[g:\2-ISOS\1  
ubuntu-14.04.1-desktop-i386.iso                100% a4fc15313ef2a516bfbf83ce44281535
```



Name	Last modified	Size	Description
Parent Directory		-	
MD5SUMS	24-Jul-2014 23:53	563	

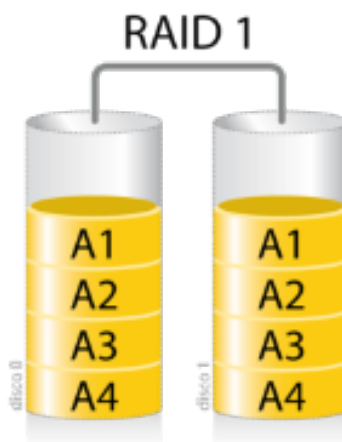
- Ejemplo práctico: **md5sum** en GNU/Linux

```
releases.ubuntu.com/14.0 x
releases.ubuntu.com/14.04.1/MD5SUMS
dccff28314d9ae4ed262cfc6f35e5153 *ubuntu-14.04-desktop-amd64.iso
c4d4d037d7d0a05e8f526d18aa25fb5e *ubuntu-14.04-desktop-i386.iso
01545fa976c8367b4f0d59169ac4866c *ubuntu-14.04-server-amd64.iso
08d25bf879e353686a974b7b14ae7d81 *ubuntu-14.04-server-i386.iso
119cb63b48c9a18f31f417f09655efbd *ubuntu-14.04.1-desktop-amd64.iso
a4fc15313ef2a516bfbf83ce44281535 *ubuntu-14.04.1-desktop-i386.iso
ca2531b8cd79ea5b778ede3a524779b9 *ubuntu-14.04.1-server-amd64.iso
3aa14ca13d52df070870d39306f4a4eb *ubuntu-14.04.1-server-i386.iso
b31731ea6cdebe1d02f8193db420886 *wubi.exe
```

- Guía para probar en W10 o W11 de forma nativa con Powershell

5.3. Disponibilidad (o accesibilidad)

- Los usuarios o sistemas con privilegios pueden acceder a la información **sin problemas** durante los periodos de tiempo establecidos
- El sistema **se recupera automáticamente** ante errores
- Ejemplos:
 - Sistema de Alimentación Ininterrumpida (SAI)
 - Creación de sistemas **RAID** (por ejemplo, FreeNAS)
 - Imagen de disco en Linux: `dd if=/dev/sda of=/dev/sdb`
 - **CPD**
 - Comprobación de disponibilidad de servicios, protocolos y aplicaciones: **NMAP**, **MBSA**, etc.
- **Alta disponibilidad** (High Availability): aplicaciones y datos operativos en todo momento y sin interrupciones, de **carácter crítico**
 - Mantener sistemas funcionando **24 horas, 7 días a la semana y 365 días al año** a salvo de interrupciones
 - El mayor nivel acepta 5 minutos de inactividad al año
 - *Disponibilidad de cinco nueves: 99,999 %*



- El **CPD (Centro de Proceso de Datos)** es la instalación donde se concentran los recursos para el tratamiento de la información
- Debe estar protegido frente a amenazas físicas y lógicas



5.4. Autenticidad / Autenticación

- Asegura la **identidad** del equipo, los mensajes o usuario que genera la información
- En ocasiones se utilizan **terceras partes confiables** (Autoridad de Certificación) para autenticar
- Ejemplos:
 - Firma digital de un fichero
 - Certificado digital
 - Login + password

5.5. No repudio

- Mecanismo que permite que **ninguno de los participantes** de una comunicación **niegue su participación** en la misma
- **No repudio en el origen**: el emisor no puede negar que envió el mensaje
 - Ejemplo: un mensaje firmado digitalmente por el emisor
- **No repudio en el destino**: el receptor no puede negar que lo recibió
 - Ejemplo: mensaje firmado digitalmente por el emisor
- Para conseguir el no repudio se cuenta con terceras partes confiables (Autoridad de Certificación)
- **No repudio en el origen y autenticidad** son objetivos estrechamente relacionados

5.6. Servicios frente a ataques

Servicio	Ataque
Disponibilidad	Interrupción (p. ej. DoS)
Confidencialidad	Intercepción (p. ej. Man in the middle)
Integridad	Modificación (p. ej. SQL Injection)
Autenticación	Falsificación (p. ej. robo de credenciales)
No repudio	Negación (p. ej. operación desde WIFI ajena)

- **Impacto**: medición y valoración del daño que puede producir a la organización un incidente de seguridad

6. Tipos de amenazas

- La **ingeniería social** es una técnica de manipulación que aprovecha el eslabón más débil del sistema de información: **el humano**
 - Una de las técnicas más usadas por los ciberdelincuentes para ganarse la confianza del usuario desprevenido y conseguir que entregue sus claves privadas o compre en sitios web fraudulentos
- Los tipos de amenazas se clasifican en tres:
 - Producidas por **personas**
 - **Lógicas**
 - **Físicas**

6.1. Amenazas producidas por personas

- Son la **principal fuente de amenaza** para un sistema
- Personal de la organización, ex-empleados, curiosos, hackers, crackers, ciberterroristas, sniffers, carders
- **Personal de la organización**: a veces de forma accidental, pero si es intencionada es muy dañino (conoce lo valioso y la infraestructura)
- **Ex-empleados**: aprovechan la falta de mantenimiento de los perfiles de acceso
- **Curiosos**: realizan **ataques pasivos** (obtener información sin destruir o modificar la original)
- **Hackers**: expertos en acceder a sistemas protegidos (no siempre con objetivo perjudicial)
- **Crackers**: hackers con objetivos perjudiciales, a menudo contratados para espionaje empresarial
- **Ciberterroristas**: espías y saboteadores informáticos que trabajan para países y organizaciones
- **Sniffers**: expertos en redes que analizan el tráfico para extraer información de los paquetes
- **Carders**: atacan los sistemas de tarjetas, como los cajeros automáticos

6.2. Amenazas lógicas

- **Vulnerabilidades de software**: errores de programación (*bugs*) o situaciones no previstas (*excepciones*)
 - El software que aprovecha dichos fallos para atacar se llama **exploit**
- **Canales ocultos**: transferencia de información por medios no destinados a ese propósito
 - Ejemplo: un **keylogger** que envía lo tecleado a un atacante remoto
- **Virus**: programa malicioso que se introduce sin permiso o conocimiento para alterar el funcionamiento del sistema
- **Worms (gusanos)**: parecidos a los virus, pero con capacidad de **autopropagarse** a través de las redes (normalmente mediante correo basura o spam)
- **Caballos de Troya (troyanos)**: malware que se presenta como legítimo e inofensivo, pero que da al atacante acceso remoto al equipo
- **Rootkits**: conjunto de software que permite un acceso de privilegio continuo **ocultando su presencia** al control de los administradores
- **Backdoors (puertas traseras)**: programa malicioso que proporciona al atacante un acceso remoto no autorizado, oculto en segundo plano
- **Spyware (software espía)**: recopila información del ordenador y la transmite a un equipo remoto sin consentimiento (suele confundirse con el **adware**)
- **Hijackers (secuestro)**: técnicas ilegales de adueñamiento o robo de información (conexiones, sesiones, servicios, navegador, etc.)
- **Bombas lógicas**: parte de código que permanece sin realizar ninguna función hasta que es activada (ausencia o presencia de ciertos ficheros, llegada de una fecha/hora concreta, etc.)

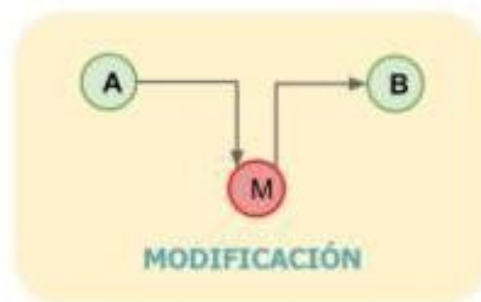
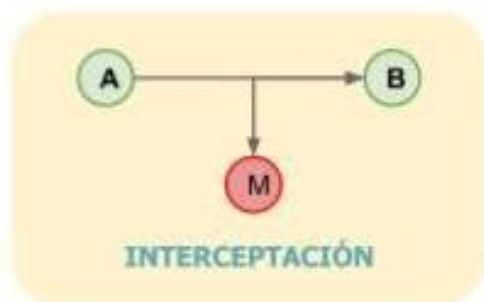
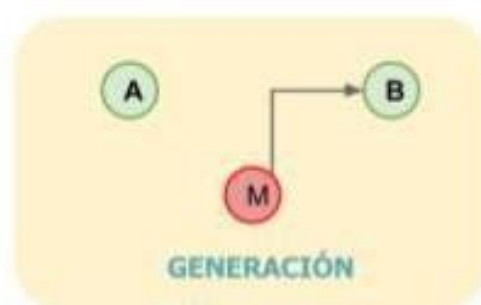
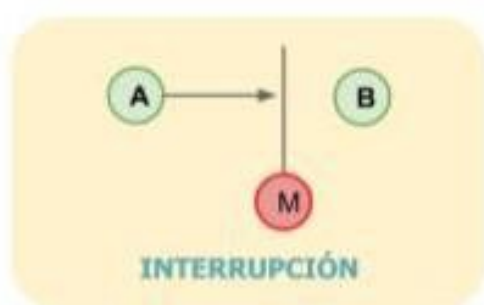
6.3. Amenazas físicas

- **Acceso físico:** cuando existe acceso físico a un recurso, ya no existe seguridad alguna sobre el mismo
 - Acceso al lugar donde se encuentra un servidor de personal no autorizado
 - Una entrada de red donde se pueda conectar un ordenador
- **Desastres del entorno y averías del hardware:** picos de sobretensión, apagones que afecten a los servidores, incendios, etc.
- **Radiaciones electromagnéticas:** cualquier aparato eléctrico emite radiaciones que se pueden capturar y reproducir con el equipamiento adecuado
- **Desastres naturales:** gotas frías, inundaciones por riadas, lluvias torrenciales, terremotos, etc.
- Otra clasificación de las amenazas: **Guerra informática**
- Otros conceptos de seguridad informática: *pretesting, sextorsión, baiting, shoulder surfing, dumpster diving...*
 - [más info](#)

7. Tipos de ataques

- Los principales ataques que puede sufrir un sistema si se aprovechan sus vulnerabilidades son:

Nombre del ataque	Descripción
Interrupción	Un recurso del sistema o de la red deja de estar disponible debido a un ataque
Generación	Falsificación del sistema. Se crea un producto difícil de distinguir del auténtico
Interceptación	Un intruso accede a la información de nuestro equipo o a la que enviamos por la red
Modificación	La información ha sido modificada sin autorización, por lo que ya no es válida



- Como ningún sistema es 100 % seguro, un **incidente de seguridad** es la materialización de una amenaza
- Debemos:

-
- Minimizar las posibilidades de **intrusión**
 - Minimizar el tiempo de **detección** de intrusiones
 - Minimizar el tiempo de **actuación** ante dichas intrusiones
 - **Reconstruir** el estado en el que estaba el sistema

8. Análisis y gestión de riesgo

- Proceso que comprende:
 - Identificación de **activos** informáticos
 - Sus **vulnerabilidades** y las **amenazas** a las que están expuestos
 - **Probabilidad** de ocurrencia e **impacto** de las mismas
- Determina los **controles** adecuados para **aceptar, disminuir, transferir o evitar** la ocurrencia del riesgo
- Un riesgo explotado causa daños o pérdidas financieras o administrativas
- Los controles, para que sean efectivos, deben implementarse **en conjunto** formando una **arquitectura de seguridad**
 - Preserva las propiedades de confidencialidad, integridad y disponibilidad de los recursos

9. Proceso de análisis de riesgos informáticos

- El análisis de riesgo genera habitualmente un documento: la **matriz de riesgo**
 - Elementos identificados, la manera en que se relacionan y los cálculos realizados
- Indispensable para lograr una correcta **administración del riesgo** (gestión de los recursos de la organización)
- Diferentes tipos de riesgo: **riesgo residual** y **riesgo total**
- Tratamiento, evaluación y **gestión** del riesgo

10. Herramientas de análisis y gestión de riesgos

10.1. Política de seguridad

- Recoge las **directrices u objetivos** de una organización con respecto a la seguridad de la información
- **Objetivo principal:** concienciar a todo el personal de la necesidad de conocer qué principios rigen la seguridad y cuáles son las normas para conseguir los objetivos
- El contenido depende de la realidad y de las necesidades de la organización
- Estándares por países y áreas; los más internacionales son los de la **ISO**
- Una política de seguridad contendrá los objetivos de la empresa, englobados en 5 grupos:
 1. Identificar las necesidades de seguridad, los riesgos y evaluar los **impactos** ante un ataque
 2. Relacionar las **medidas de seguridad** que deben implementarse para afrontar los riesgos
 3. Proporcionar una perspectiva general de las **reglas y procedimientos** para los diferentes departamentos
 4. Detectar todas las **vulnerabilidades** y controlar los fallos de los activos
 5. Definir un **plan de contingencias**

10.2. Ejemplos de herramientas

- **MAGERIT**: metodología de análisis y gestión de riesgos (*Methodology for Information Systems Risk Analysis and Management*)
- **PILAR**: procedimiento informático-lógico para el análisis y gestión de riesgos que sigue la metodología MAGERIT
 - De uso exclusivo de la **Administración Pública Española**
- Documento de apoyo: [Plan de contingencia: guía y ejemplo](#)

11. Auditoría

- Proceso llevado a cabo por profesionales capacitados que consiste en **recoger, agrupar y evaluar evidencias**
- Determina si un Sistema de Información:
 - Salvaguarda el **activo empresarial**
 - Mantiene la **integridad** de los datos
 - Lleva a cabo eficazmente los **finés** de la organización
 - Utiliza **eficientemente** los recursos
 - Cumple las **leyes y regulaciones** establecidas

11.1. Tipos de auditoría

- **Auditoría interna**: se realiza desde dentro de la empresa, sin contratar a personas ajenas
- **Auditoría externa**: la empresa contrata a personas de fuera para que realicen la auditoría
- Auditar consiste principalmente en **estudiar los mecanismos de control** implantados
 - Determinar si son adecuados y cumplen los objetivos o estrategias
 - Establecer los cambios que deberían realizarse

11.2. El informe de auditoría

- Tras el análisis e identificación de vulnerabilidades, el informe contiene como mínimo:
 - Descripción y características de los **activos** y **procesos** analizados
 - Análisis de las **relaciones** y **dependencias** entre activos o en el proceso de la información
 - Relación y evaluación de las **vulnerabilidades** detectadas
 - Verificación del cumplimiento de la **normativa**
 - Propuesta de **medidas** preventivas y de corrección

11.3. Herramientas de análisis

- **Manuales**: observación de activos, procesos y comportamientos, mediciones, entrevistas, cuestionarios, cálculos, pruebas de funcionamiento
- **Software específico (CAAT)**: Computer Assisted Audit Techniques
 - Mejoran la eficiencia de la auditoría
 - Proporcionan una imagen en tiempo real del SI
 - Realizan pruebas de control y emiten informes con vulnerabilidades y normativas incumplidas
- La auditoría puede ser:
 - **Total**: sobre todo el sistema de información
 - **Parcial**: sobre determinados activos o procesos

12. Plan de contingencias

- Instrumento de gestión con las medidas que garantizan la **continuidad del negocio**
 - Protege el SI de los peligros que lo amenazan
 - O lo recupera tras un impacto
- Consta de **tres subplanes independientes**:
 - Plan de **respaldo**
 - Plan de **emergencia**
 - Plan de **recuperación**

12.1. Plan de respaldo

- Ante una amenaza, se aplican medidas **preventivas** para evitar que se produzca un daño
- Ejemplos:
 - Crear y conservar en lugar seguro **copias de seguridad**
 - Instalar **pararrayos**
 - Hacer **simulacros** de incendio

12.2. Plan de emergencia

- Contempla qué medidas tomar cuando la amenaza **se está materializando** o acaba de producirse
- Ejemplos:
 - **Restaurar** de inmediato las copias de seguridad
 - Activar el sistema automático de **extinción de incendios**

12.3. Plan de recuperación

- Indica las medidas que se aplicarán cuando **se ha producido un desastre**
- El objetivo es evaluar el impacto y regresar lo antes posible a un estado **normal de funcionamiento**
- Ejemplos:
 - Tener un **lugar alternativo** donde continuar la actividad
 - Sustituir el material deteriorado
 - Reinstalar aplicaciones y restaurar copias de seguridad

13. Referencias

- Formatos:
 - [Transparencias](#)
 - [PDF](#)
 - [Página web](#)
 - [EPUB](#)
- Alojado en [Github](#)